令和2年秋 応用情報 午後問1【情報セキュリティ】 小南解题

一、整体背景梳理

- **业务背景与现实痛点：**
  - **A社业务模式**：针对中小学及高考生的通信教育机构，核心数据包括受攻学员个人信息与学习履历。
  - **运维架构现状**：受讲生管理系统部署于 E社数据中心，由外包 F社技术人员在A社内部“系统运用管理室”远程运维。
  - **管理漏洞**：虽然制定了《情报安全管理规程》，但缺乏技术强制手段。员工存在可移动介质乱用、私自访问外网及私用邮件等违规隐患。
- **理论框架（不正のトライアングル / 不正三要素理论）：**
  - **动机（Motivations）**：员工经济压力、离职报复或私利驱使。
  - **机会（Opportunity）**：系统权限过大、审计缺失、设备无管控（**本题技术改良的核心切入点**）。
  - **正当化（Rationalization）**：员工心理防线坍塌，认为“大家都在做”或“公司制度不合理”。
- **终极解法：技术管控 + 审计追溯 + 宣贯抑止（组合拳方案）：**
  - **技术堵漏（降低“机会”）**：引入 PC管理系统控制未授权U盘；代理服务器（Proxy）开启 URL白名单过滤；邮件管理系统开启“附件发信需上司审批”。
  - **日志审计（数字化取证）**：开启 Proxy 身份认证与日志记录、PC全量操作日志及邮件归档（Mail Archive）。
  - **公示告知（心理抑止）**：向全员告知安全技术与审计监控措施的存在，提高心理威慑（捕まるリスクを高める / 犯行を難しくする）。

二、逐题深度解析

設問1：安全规程填空（区分与权限）

- **参考答案：**
  - **a**：才（秘密）

- **b**：イ（権限）

- **逻辑拆解：**
  - **填空 a**：在安全规程中，对保有资产进行定级分类的术语通常称为“机密区分”或“秘密区分”。查看选项群，最符合信息资产分类印记描述的是“秘密”（秘密区分）。
  - **填空 b**：基于**最小权限原则（Principle of Least Privilege）**，对系统使用者仅赋予业务执行所必需的最少功能“权限”（権限）。

設問2：内部不正的技术应对措施

(1) 下划线①：利用 PC管理系统的“设备控制功能”抑制信息非法带出的方法？（35字以内）

- **参考答案：**
  - **許可されていない可搬型記憶媒体のPCへの接続を拒否する**（27字）
  - *（译文：拒绝将未经许可的可移动存储介质连接至PC）*
- **逻辑拆解：**
  - **审题关键**：题目明确 A社规定“经管理者批准后，允许将数据下载到被许可的可移动存储介质”。
  - **答题红线**：不能写“切断所有USB接口”或“禁止一切U盘接入”，这会影响合法合规的业务。
  - **核心机理**：设备控制功能（Device Control）的核心在于区分“授权设备”**与**“非授权设备”，通过拒绝未授权介质的挂载与连接，从源头上切断非法下载带出的途径。

(2) 下划线②：针对带附件邮件，最合理的“指定处理”策略？（四选一）

- **参考答案：**
  - **ア**（あらかじめ指定された上司に通知し、上司の承認後に送信する）
- **逻辑拆解：**
  - **选项解析**：
    - **ア（正确）**：重要信息带出需上司批准。将带附件的邮件拦截并送交指定主管审批，既能防误发送，也能阻止恶意员工私自带出机密。

- **イ（排除）**：现行流程就是“发信者本人二次确认”，这无法防范故意捣鬼的内部作恶者。
- **ウ（排除）**：此为传统 PPAP 做法（密码分开发），无法阻止内部人员主动将机密文件连同密码一起发给外部私人邮箱。
- **エ（排除）**：直接删除附件会严重破坏 A社正常对外合作业务。

(3) 下划线③：对于未列入 URL白名单但业务确实需要的网站，应提供什么手段？（20字以内）

- **参考答案：**
  - **利用したいWebサイトの認定申請**（16字）
  - *（別解：Webサイトの利用認定申請手続き / 17字）*
- **逻辑拆解：**
  - **上下文线索**：文中明确指出“白名单由信息安全委员会认定后，由信息系统部进行配置”。
  - **流程闭环**：当员工因业务需求需要访问未放行的网站时，系统必须提供一个正规的“认定申请流程”，由委员会审查评估后追加至白名单。

設問3：日志审计、归档与公示抑止

(1) 下划线④：通过日志和归档明确法律证据性的技术手段称为什么？（15字以内）

- **参考答案：**
  - **デジタルフォレンジックス**（12字）
  - *（別解：ディジタルフォレンジックス / 12字）*
- **逻辑拆解：**
  - **标准概念**：**数字取证 / 计算机取证（Digital Forensics）** 指在发生安全事件时，收集、保全、分析计算机设备中的电子数据，以提供具备法律效力的证据。

(2) 下划线⑤：为了能在 Proxy 日志中根据⑤（作业者ID）精准定位具体人员，Proxy 服务器需新增什么处理？（6字以内）

- **参考答案：**

- **利用者認証**（5字）

- **逻辑拆解：**
  - **问题根源**：A社网络采用 DHCP 动态分配 IP 地址，且目前“代理服务器未开启使用者认证（プロキシサーバでは、利用者認証は行っていない）”。此时日志里只有动态 IP，无法精准绑定到具体个人。
  - **解决手段**：在 Proxy 上启用“利用者认证”（用户认证），强制要求提供身份凭证，将网络请求与作业者 ID 绑定。

(3) 下划线⑥：将上述安全措施向社内公示，为何能起到抑制内部不正的作用？说明其中一个理由。（30字以内）

- **参考答案：**（二选一即可）
  - **理由 1（从“犯罪难度”角度）：**
    情報を不正に社外に持ち出すのが難しいことが分かるから（26字）
    （译文：因为员工意识到将信息非法带出公司变得非常困难）
  - **理由 2（从“被捕风险”角度）：**
    不正を隠し通せないことが分かるから（17字）
    （译文：因为员工意识到自己的不正当行为无法隐瞒隐藏）
- **逻辑拆解：**
  - **情境预防理论（Situational Crime Prevention）：**
    1. **犯行を難しくする（增加作案难度）**：告知了 U盘管制、上司审批、URL过滤，让潜性作恶者明白技术壁垒高，难以得逞。
    2. **捕まるリスクを高める（提高暴露风险）**：告知了全量操作日志、Proxy认证、邮件归档监控，让潜性作恶者明白“留痕必被抓”，破坏其侥幸心理。

三、核心考点速查

考察维度	考点核心	原理要点
内部不正理论	不正のトライアングル（不正三要素）	动机、机会、正当化。技术手段侧重降低“机会”，社内告知公示侧重降低“诱因”与提高“被抓风险”。
设备与外发管控	デバイス制御 & 上司承認	拒绝未授权存储设备接入 PC；带附件的外发邮件须经上司审批，打破单人私自带出链路。
动态访问控制	URLフィルタリング & 認定申請	基于白名单机制封堵非业务网站，配合“认定申请”流程平衡安全与业务灵活性。

电子取证与审计	デジタルフォレンジックス & 利用者認証	Proxy 开启“利用者认证”解决 DHCP 动态 IP 溯源难题；全量日志与 Mail Archive 构成数字取证依据。